



Lab 14 — Apply the CSA Agentic Extensions to the NIST AI RMF

Topic 04: Security Controls for Agentic AI, Risk Assessment and Implementation Roadmap

Objective: Implement agentic-specific governance by applying autonomy tiering, delegation accountability, an agent registry and behavioural telemetry.

Goal: The NIST AI RMF treats a read-only recommender and an autonomous executor identically. The CSA agentic profile closes that gap. You will apply its extensions to NovaBank's agent estate: tier every agent, document delegation accountability, build the agent registry and define behavioural telemetry.

What you'll build: An agentic governance pack: five agents tiered with justification, a delegation accountability record, a completed agent registry and a behavioural telemetry specification.

Tools and data: Agent estate pack (novabank-agents.md), CSA agentic RMF profile reference, registry template

Data files in this lab

- data/agent-registry-template.csv
- data/incident-playbook-template.md
- data/novabank-agents.md
- data/telemetry-spec-template.csv

Step-by-step

1. Open novabank-agents.md in labs/lab-14-csa-agentic-profile/data/. Five agents are described: NovaAssist, a fraud triage agent, an internal IT helpdesk agent, a marketing content agent and a reconciliation agent.
2. Apply AG-GV.1 Autonomy Tier Classification. Assign each agent a tier: Tier 1 supervised, Tier 2 constrained, Tier 3 broad with monitoring, Tier 4 full autonomy. Justify each from what the agent can do, not from how it is described.
3. State the oversight obligation that comes with each tier: what review, what approval and what monitoring frequency. The obligation must escalate with the tier or the tiering is decorative.
4. Apply AG-GV.2 Delegation Accountability. For the reconciliation agent, which delegates to a sub-agent, document the oversight boundary, the escalation trigger, the scope of delegated authority and the accountability lineage back to a named human.

5. Apply AG-GV.3 Agent Lifecycle Registry. Build the registry with columns: agent ID, owner, purpose, autonomy tier, tools and scopes, data reached, sub-agents, review date and kill-switch procedure.
6. Apply AG-MP.1 Tool Risk Classification and AG-MP.2 Action-Consequence Analysis. For the fraud triage agent, draw the consequence graph: which tool sequences lead to a customer account being frozen, and what happens if that decision is wrong.
7. Apply AG-MP.3 Multi-Agent Topology Risk for the reconciliation agent and its sub-agent: identify the trust boundary between them and how a compromise would propagate.
8. Apply AG-MS.1 Agentic Behavioural Telemetry. Specify the runtime metrics: action velocity, permission escalation rate, cross-boundary invocations, delegation depth and exception rate, each with a baseline and an alert threshold.
9. Apply AG-MG.1 Agentic Incident Classification. Write a one-line containment playbook for each of the four incident types: agent compromise, behavioural hijack, runaway agent and delegation chain compromise.
10. Apply AG-MG.3 Agent Decommissioning to the marketing content agent, which is being retired: credential revocation, memory disposition, audit log preservation and downstream updates.

Test it

All five agents are tiered with a justification drawn from their capabilities, your registry has no blank kill-switch field, and your telemetry metrics each have a baseline and a threshold. You can explain why tiering by capability beats tiering by job title.

Training use only. The organisation, data and individuals in this lab are fictional. Security techniques taught here must only be applied to systems you own or have written authorisation to test.